

Case Studies on Compliance and Security

The case studies of “Proving Compliance in Regulated Environments” and “Relying on Production Telemetry for ATM Systems” show us how DevOps in regulated industries can come with different challenges related to compliance and security. The following will summarize the case studies and display how we need to use modern engineering methods to meet regulatory compliance and security expectations better than simply using traditional practices.

“Proving Compliance in Regulated Environments” was a case study in the DevOps Handbook that showed how organizations can better meet regulatory requirements by automating controls and allowing for auditors to access real time data through self service tools. With many organizations such as Hearst Media and GE moving on to cloud infrastructure, new challenges have arisen for meeting legal and audit requirements. The traditional methods of auditing, like manually sampling subsets of static servers and collecting screenshots do not work well with the more dynamic modern systems that we use. Since infrastructure is coded, systems autoscale, and deployment is continuous, old audit strategies are not very efficient when it comes to modern DevOps work patterns. Bill Shin of AWS, would go on to address this issue by integrating auditors into the control design process. They took a sprint based approach and assigned controls per sprint and tailored evidence generation to meet the audit needs. Instead of having to rely on screenshots, they streamed data into telemetry systems that allowed the auditors to self service the specific data that they needed.

The main lesson to take away from this case study was that we need to translate legal and regulatory language into engineering actions. To break down the walls between engineering and audit, AWS created a DevOps Audit Defense tool kit that serves as a model for meeting actual compliance challenges in environments where compliance is needed such as HIPAA, etc. At the end of the day, for effective compliance in DevOps we need collaboration between auditors and engineers, automated evidence collection and use of telemetry, and regulatory language needs to be changed into specific controls that are testable and monitorable.

The second case study was “Relying on Production Telemetry for ATM Systems”. In this case study, a financial services company’s ATMs have backdoors put in by a developer that allow for money to be stolen at specific times. Even with a traditional change approval process and separation of duties, this was not caught through code review. The fraud was found through production telemetry when some unusual behavior was found in the ATM logs. Thanks to this the issue was caught and fixed before the audit process found the discrepancies of missing cash. This shows the importance and effectiveness of production monitoring and real time visibility when it comes to finding discrepancies rather than only relying on code reviews. Even though static analysis and separation of roles are useful, they will not find all security breaches that come up. The main takeaways from this case study are that, production telemetry gives us

visibility and detection of weird behaviors, compliance processes should be supplemented with actual real time operational data, and traditional approvals and code reviews are not enough for preventing possible attacks, especially internal.

These case studies show us how compliance, security, and auditing should be done in the modern DevOps environment. The older methods are not enough or are outdated for the more dynamic systems of modern times. We should instead use automation, telemetry, and cross functional collaboration. By taking this approach, audits are faster, more accurate, and help us react to threats proactively.